

BEFORE Placeholder

AFTER

Tier 1 (Critical) Supplier Evidence Pack — Request List

Purpose: This request supports due diligence for a Critical supplier with elevated data sensitivity, privilege, connectivity, or business criticality. Provide evidence where available; if a control isn't met, describe the gap and your remediation plan/timeline.

Supplier: _____ Service: _____ Assessment date:
_____ Supplier contact: _____

1) Security governance & contacts

- Named security contact for incidents and assurance
- High-level security policy/overview (table of contents acceptable)
- SDLC/secure engineering overview (for SaaS/software providers)

2) Identity & access management

- MFA enforcement approach (incl. admin/privileged users)
- SSO/SAML/OIDC support details + role model (RBAC) documentation
- Privileged access management approach (JIT/JEA, break-glass, approvals)
- User lifecycle: joiner/mover/leaver and access review cadence Evidence examples:
- IAM/SSO configuration guide, screenshots acceptable (redacted)
- Access review procedure or last access review record (redacted)

3) Environment & tenant security (if SaaS)

- Tenant isolation model (logical/physical), customer data segregation

- Secure configuration/baselines for tenant administration
- Hardening guides for any agents/connectors deployed in customer environments

4) Network security & connectivity

- Connectivity model (VPN/private link/API) and security controls
- IP allowlisting / mTLS / certificate management approach (if applicable)
- Segmentation approach for production systems Evidence examples:
- Network diagram (high level), secure connectivity design notes

5) Logging, monitoring & detection

- Audit logging coverage: admin actions, auth events, data access where applicable
- Log retention periods and customer access/export options
- SOC monitoring coverage (24x7 vs business hours), alert handling process Evidence examples:
- Sample audit log fields (redacted), logging documentation

6) Vulnerability management & patching

- Vulnerability scanning approach (internal/external) and cadence
- Patch SLAs (critical/high/medium) and emergency patch process
- Pen test summary from last 12 months (executive summary acceptable) Evidence examples:
- Last pen test executive summary + remediation status (redacted)
- Vulnerability management policy or process doc

7) Secure development (for software/SaaS)

- Code review and CI/CD controls (branch protection, approvals)
- SAST/DAST/dependency scanning approach
- Secrets management approach (no secrets in code, rotation) Evidence examples:

- SDLC overview, CI controls description

8) Data protection & privacy

- Data types processed; data flow overview (where data is stored/processed)
- Encryption in transit and at rest (algorithms/high-level ok)
- Key management approach (KMS/HSM), rotation practices
- Data retention/deletion approach; secure deletion method
- GDPR support: DPA availability, breach notification commitment, sub-processor disclosures
Evidence examples:
- DPA template, privacy notice, encryption statement

9) Incident response

- Incident response process overview + severity classification
- Breach notification timelines and communication process
- Evidence of testing (tabletop/exercise) within last 12–18 months (summary ok) Evidence examples:
- IR runbook excerpt, last exercise summary (redacted)

10) Resilience & recovery

- Availability design (redundancy, backups, failover model)
- RTO/RPO capabilities for the service
- DR testing cadence and last DR test summary (high-level acceptable) Evidence examples:
- DR overview, last DR test summary

11) Third parties / sub-processors (fourth party)

- Current sub-processor list relevant to service delivery

- Process to assess/approve sub-processors
- Commitment to notify material sub-processor changes Evidence examples:
- Sub-processor register excerpt or published list link/text (no URLs required here)

12) Assurance / certifications (provide what you have)

- ISO 27001 certificate + Statement of Applicability (if available)
- SOC 2 Type II report (preferred) or Type I (if Type II not available)
- PCI/other attestations if relevant If none: provide alternative assurance evidence (pen test summary, internal audit summary)

13) Commercial / contractual security (templates acceptable)

- Security schedule/addendum acceptance position (mark-up acceptable)
 - Right-to-audit stance and practical approach
 - Data residency commitments (regions)
 - Support model for security incidents (contacts, response times)
-

If you can't provide an item

For each missing item, respond with:

- Reason (e.g., "not available", "in progress", "policy restriction")
- Compensating control(s)
- Remediation plan and target date

Supplier response checklist

☐ Evidence pack completed ☐ Gaps and remediation plan provided ☐ Sub-processor list provided
☐ Security contact confirmed ☐ Incident notification commitments confirmed